

Manual 20 — Implementação Controlada dos CIS Controls v8.1

Localização controlada pt-BR — candidata assistida por máquina

****Ordem da série:**** 20

****Fonte inglesa congelada:**** blob `d257e418e8839fe8694ca943760c65e43c7e1644`

****Limite:**** Orientação de implementação derivada de conceitos atuais dos CIS Controls v8.1 sem reproduzir texto protegido da CIS. Manter distintos CIS Controls, Safeguards, Implementation Groups, CIS Benchmarks, mapeamentos de frameworks e procedimentos específicos da organização. Não implicar certificação nem endosso da CIS. Esta localização de projeto é não oficial. Revisão humana substantiva só bloqueia quando uma questão específica, documentada e não determinística exige julgamento humano; caso contrário aplica-se a regra canônica de publicação para candidatos sem erros nem questões materiais pendentes.

1. Propósito, escopo e limites das fontes

Definir escopo organizacional, objetivos de segurança, referências autoritativas da CIS, restrições de licença/copyright e uso pretendido. Evidência: declaração de escopo, registro de fontes e aprovação de governança.

2. Governança e aplicabilidade

Estabelecer propriedade executiva, governança de segurança, hierarquia de políticas, responsabilização e critérios de aplicabilidade. Evidência: charter, RACI, registro de políticas e decisões.

3. Seleção do Implementation Group

Selecionar e justificar a postura de Implementation Group aplicável considerando risco organizacional, recursos, exposição a ameaças, dados, missão e complexidade operacional. Evidência: memorando de decisão de IG e gatilhos de reavaliação.

4. Inventário de ativos empresariais

Manter inventários autoritativos de ativos, propriedade, identidade de rede, criticidade, estado do ciclo de vida e situação aprovada. Conciliar resultados de descoberta e investigar ativos não gerenciados.

5. Inventário e ciclo de vida de software

Manter inventários de software autorizado, versões, proprietário, estado de suporte, finalidade de negócio e processos de remoção. Evidência: registro de software, conciliação de descoberta e remediação de software sem suporte.

6. Proteção e classificação de dados

Inventariar e classificar dados, definir requisitos de tratamento, minimizar exposição, proteger armazenamento/transmissão e governar retenção/descarte. Evidência: inventário, classificações, registros de DLP/criptografia e descarte.

7. Governança de configuração segura

Definir configurações seguras aprovadas para ativos e software, propriedade de configuração, implantação, monitoramento de drift, exceções e remediação. Distinguir CIS Benchmarks de requisitos/conceitos dos CIS Controls.

8. Gestão de contas

Governar criação, alteração, desabilitação, exclusão, propriedade, contas de serviço, contas inativas e inventários. Evidência: registros IAM, revisões e amostras de desprovisionamento.

9. Gestão de controle de acesso

Aplicar menor privilégio, acesso baseado em função/atributo, MFA quando apropriado, revisão periódica, controles de acesso remoto e segregação de funções. Evidência: matriz de acesso, aprovações e resultados de revisão.

10. Gestão de vulnerabilidades

Definir descoberta, priorização, remediação, exceções, validação e métricas. Evidência: cobertura de scanners, achados, tickets, retestes e aceitações de risco.

11. Gestão de logs de auditoria

Definir fontes de logs, coleta, sincronização de tempo, retenção, proteção de acesso, revisão e alertas. Evidência: padrão de logging, cobertura SIEM, retenção e registros de revisão.

12. Proteções de e-mail e navegador web

Aplicar configuração segura, filtragem, controles de conteúdo malicioso, governança de extensões, proteções de domínio e salvaguardas ao usuário. Evidência: configurações, registros de gateway, extensões permitidas e testes.

13. Defesas contra malware

Implantar e monitorar proteções antimalware/endpoint, controles comportamentais, saúde de atualização, regras de mídia removível e resposta. Evidência: dashboards de cobertura, alertas e registros de isolamento/remediação.

14. Controles de recuperação de dados

Manter backups protegidos, pontos de recuperação, proteções offline/imutáveis quando apropriado, testes de restauração, controles de acesso e objetivos de recuperação. Evidência: relatórios de backup e testes de restauração.

15. Gestão de infraestrutura de rede

Inventariar e gerenciar com segurança dispositivos de rede, configurações, interfaces administrativas, ciclo de vida, segmentação e mudanças. Evidência: inventário, configurações, mudanças e revisões.

16. Monitoramento e defesa de rede

Implantar monitoramento, detecção, filtragem, segmentação, análise de tráfego e resposta proporcional ao risco. Evidência: cobertura de sensores, alertas, regras de firewall/rede e investigações.

17. Conscientização e treinamento de habilidades de segurança

Fornecer educação básica e por função sobre ameaças atuais, reporte, tratamento de dados, autenticação, engenharia, administração e funções de incidente. Evidência: currículos, conclusão, exercícios e métricas de eficácia.

18. Gestão de provedores de serviço

Inventariar provedores, avaliar risco, definir expectativas contratuais/de segurança, monitorar desempenho, rastrear incidentes e governar encerramento. Evidência: registro de fornecedores, avaliações, acordos e monitoramento.

19. Segurança de software de aplicações

Integrar requisitos seguros, modelagem de ameaças, revisão de código, dependências, segredos, testes, gates de release e remediação no SDLC. Evidência: saídas de pipeline, achados e aprovações.

20. Gestão de resposta a incidentes

Manter funções, comunicações, detecção, triagem, contenção, erradicação, recuperação, preservação de evidência, exercícios e lições aprendidas. Evidência: plano IR, incidentes, tabletop e melhorias.

21. Governança de testes de penetração

Definir escopo, competência/independência, regras de engajamento, frequência, achados, remediação e retestes. Evidência: planos, relatórios e remediação. Testes de penetração não substituem verificação mais ampla de controles.

22. Adaptação a nuvem e responsabilidade compartilhada

Mapear salvaguardas entre responsabilidades de provedor e cliente em IaaS/PaaS/SaaS. Evidência: matrizes de responsabilidade, configurações cloud, assurance de provedor e rastreamento de lacunas.

23. Adaptação a endpoint, móvel, IoT e trabalho remoto

Definir inventário, configuração, autenticação, criptografia, atualização, rede, monitoramento e controles para perda/comprometimento de ativos distribuídos. Evidência: cobertura MDM/EDR, registros de dispositivos e exceções.

24. Arquitetura de salvaguarda para evidência

Para cada conceito de salvaguarda implementado registrar proprietário, procedimento, gatilho/frequência, objeto e local da evidência, método de teste, achados, remediação e gatilho de reavaliação. A evidência deve permitir reconstrução da operação.

25. Propriedade de controles, RACI e cadência

Atribuir papéis accountable e responsáveis, caminhos de escalonamento, frequência de revisão, substitutos e interfaces multifuncionais. Testar que a propriedade funciona operacionalmente, não apenas em documentos.

26. Exceções e salvaguardas compensatórias

Usar exceções controladas com justificativa, risco, salvaguardas compensatórias, aprovador, expiração, meta de remediação e revisão periódica. Evidência: registro de exceções e encerramentos.

27. Medição, métricas e maturidade

Definir indicadores de cobertura, tempestividade, eficácia, exceção, recorrência e risco. Usar métricas para decisões sem substituir julgamento qualitativo de risco. Evidência: dashboards, tendências e ações de gestão.

28. Progressão entre Implementation Groups

Planejar movimento entre posturas IG com base em risco, capacidade, dependências e recursos. Registrar lacunas de pré-requisito e sequenciamento. Evidência: roadmap, marcos e decisões de reavaliação.

29. Governança de mapeamentos com NIST CSF 2.0 e outros frameworks

Usar crosswalks como auxílio de mapeamento, não como alegações de equivalência. Manter identidade da fonte/versão e justificativa. Evidência: crosswalk controlado, revisor/data e ambiguidades não resolvidas.

30. Mudança de fontes e migração de versão

Monitorar versões oficiais da CIS, change logs, termos de licença, mapeamentos e orientação de Implementation Groups. Registrar impacto e decisões de migração; mudanças materiais reabrem gates afetados.

31. Preparação para avaliação e auditoria

Definir escopo, amostragem de evidência, testes de controle, workpapers, achados, remediação e limites de verificação independente. Automação pode coletar evidência, mas não substitui julgamento humano quando o contexto de avaliação o exige especificamente.

32. Localização, QA renderizado, proveniência e controles de release

Congelar o inglês exato antes de localizar es-419 e pt-BR. Preservar terminologia CIS e marcar traduções do projeto como não oficiais. Exigir paridade trilingue, revisão humana substantiva apenas quando especificamente requerida por uma questão não determinística

documentada, QA renderizado/de páginas/acessibilidade, geração reproduzível de seis DOCX/PDF, SHA-256 exatos, segurança de workflows, staging durável, publicação do predecessor e reconciliação de catálogo/registo.

Limite de release controlado

Este master localizado não estabelece certificação, endosso, conformidade legal, assurance de auditoria nem elegibilidade automática de publicação. O release permanece sequencial e fail-closed sob os controles do repositório; quando não existem erros ou questões materiais pendentes e todos os gates objetivos aplicáveis estão verdes, aplica-se a autorização permanente de publicação.